

ANALISI DEL CAMPIONE WANNACRYPT0R SU TRIA.GE

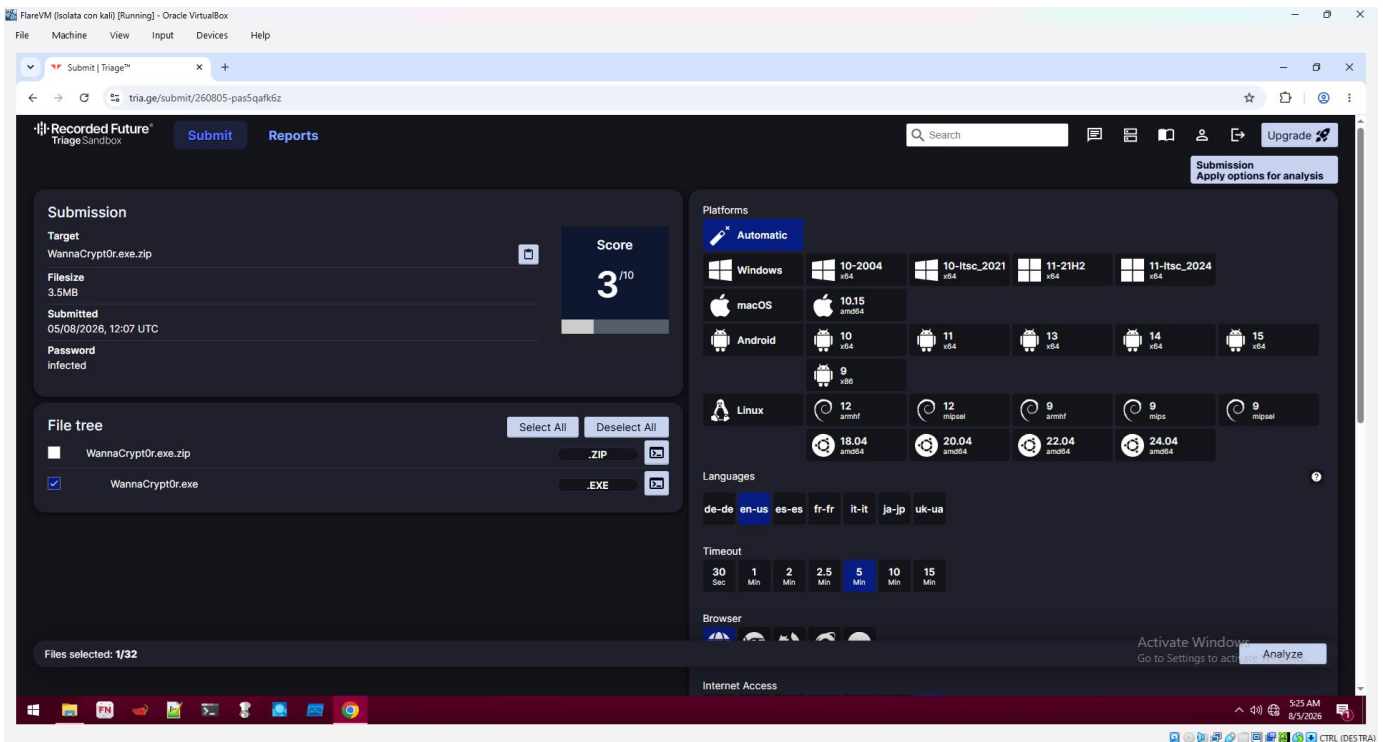
Obiettivo: analizzare il campione WannaCrypt0r.exe tramite la sandbox tria.ge, senza avviarlo sulla FLARE-VM, osservandone il comportamento e il traffico di rete.

Ambiente di laboratorio: FLARE-VM utilizzata per la gestione del campione e per l'accesso alla piattaforma. L'esecuzione è avvenuta esclusivamente nell'ambiente isolato di tria.ge.

Strumenti utilizzati: tria.ge, report PDF e cattura PCAPNG generati dalla piattaforma.

1. Procedura

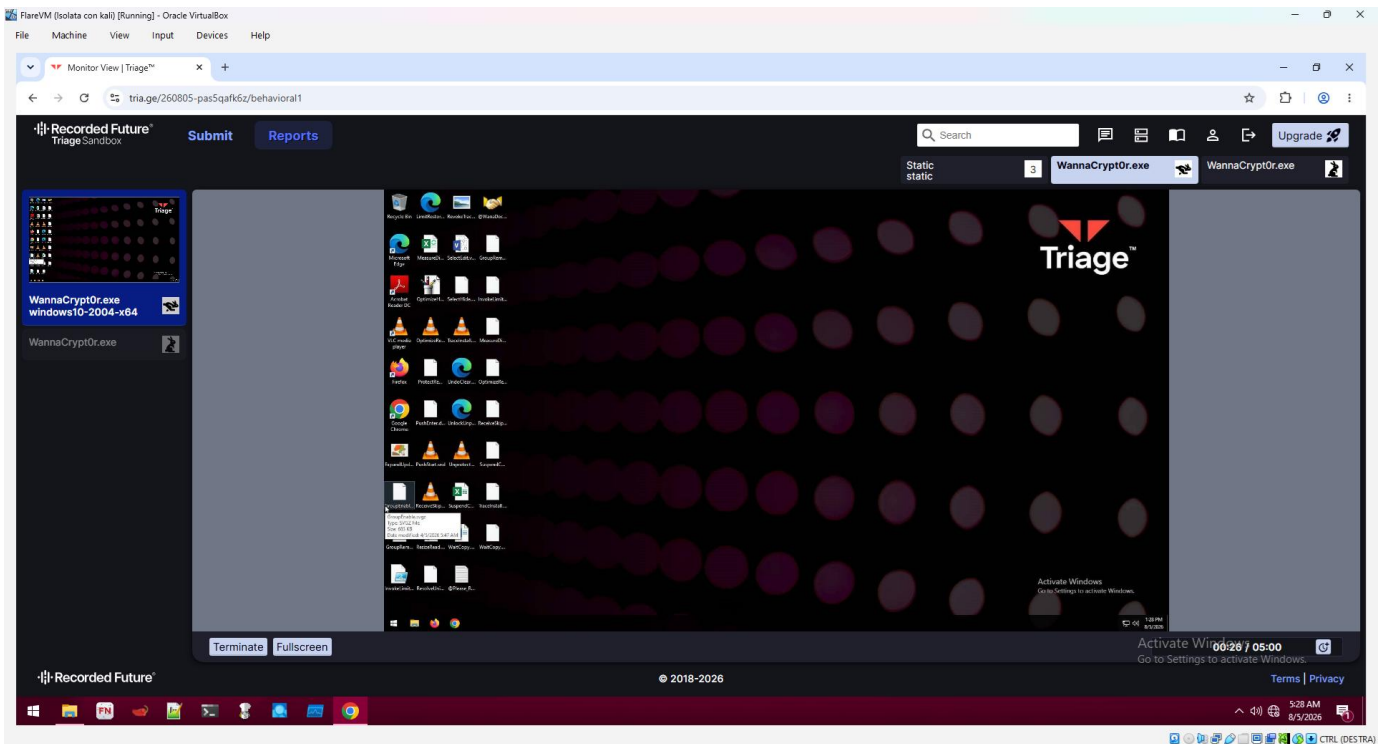
Il file WannaCrypt0r.exe.zip è stato caricato su tria.ge ed è stato selezionato l'eseguibile contenuto nell'archivio. L'analisi è stata avviata con configurazione automatica su Windows e con un tempo massimo di cinque minuti.



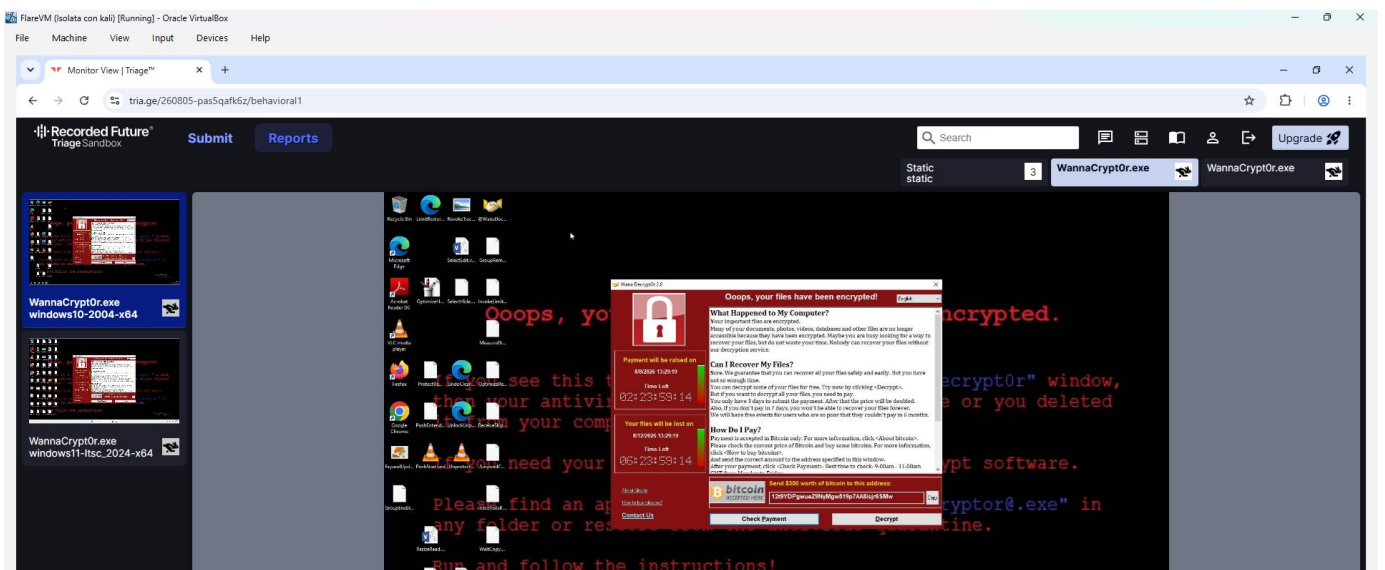
1 - Sopra: Caricamento del campione e selezione di WannaCrypt0r.exe per l'analisi nella sandbox.

2. Esecuzione nella sandbox

Dopo l'avvio, la piattaforma ha eseguito il campione in due ambienti Windows e ha registrato in tempo reale le modifiche prodotte. Durante i primi secondi era ancora visibile il desktop della macchina di analisi.



2 - Sopra: Analisi dinamica in corso nell'ambiente Windows 10 della piattaforma tria.ge.



3 - Sopra: Comparsa della schermata di riscatto e modifica dello sfondo del desktop durante l'esecuzione.

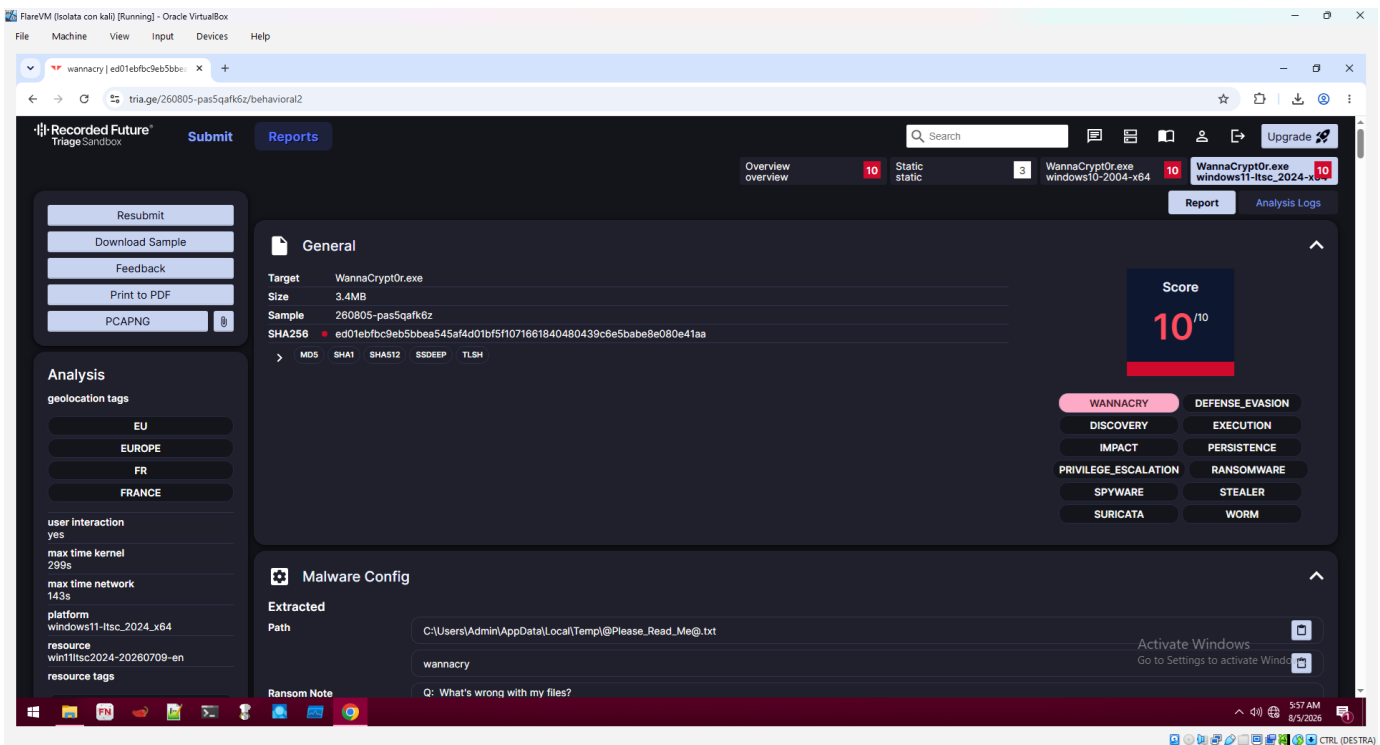
3. Risultati del report

Nome del file: WannaCrypt0r.exe

Tipo e dimensione: eseguibile Windows PE EXE, 3,4 MB

SHA-256: ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa

Classificazione: WannaCry / ransomware e worm; punteggio finale 10/10, classificato come Known bad.



4 - Sopra: Riepilogo finale del report con hash SHA-256, punteggio 10/10 e categorie associate al campione.

3.1 Comportamenti osservati

Il report mostra la sequenza tipica di un ransomware: il campione prepara l'ambiente, rilascia e avvia altri componenti, riduce le possibilità di recupero e infine mostra la richiesta di riscatto. La finestra Wanna Decrypt0r e lo sfondo modificato servono a comunicare alla vittima che i file sono stati cifrati e che viene richiesto un pagamento.

L'azione più pericolosa riguarda la disattivazione dei metodi di ripristino. Il malware esegue comandi come `vssadmin delete shadows /all /quiet` e `wmic shadowcopy delete` per eliminare le copie shadow. Utilizza inoltre `bcdedit` per disabilitare il ripristino automatico e `wbadmin delete catalog -quiet` per rimuovere il catalogo dei backup. Queste operazioni non cifrano direttamente i file, ma rendono molto più difficile recuperarli senza una copia esterna.

Il campione modifica anche permessi e attributi dei file tramite `icacls` e `attrib`, esegue script batch e VBS e rilascia vari file nella cartella temporanea. Tra gli elementi osservati compaiono `taskdl.exe`, `tasksche.exe`, `taskhsvc.exe` e componenti Tor come `tor.exe` e diverse DLL. Sono presenti anche messaggi di riscatto in numerose lingue con estensione `.wnry`. La sandbox segnala inoltre l'enumerazione dei processi e la lettura di dati del profilo dei browser, anche se il report non mostra in modo preciso eventuali credenziali effettivamente sottratte.

3.2 Persistenza e chiavi di registro

La persistenza permette al malware di riavviarsi dopo un nuovo accesso a Windows. Nel report sono state osservate soprattutto le seguenti modifiche:

Chiave o elemento	Azione	Significato
HKLM\SOFTWARE\WOW6432Node\Microsoft\Windows\CurrentVersion\Run Valori osservati: fydjjlcp217 e crhfwgcvdzj388	Impostazione di una voce Run che richiama tasksche.exe	È la modifica più pericolosa: il componente viene avviato automaticamente a ogni accesso a Windows, mantenendo la persistenza.
HKU\S-1-5-21-...\Control Panel\Desktop\Wallpaper	Impostazione dello sfondo con l'immagine di riscatto	Produce un effetto visibile e indirizza la vittima verso le istruzioni del ransomware. Non è una chiave di persistenza.
HKLM\SYSTEM\ControlSet001\Control\NLS\Language	Lettura della lingua del sistema	È un'attività di ricognizione: permette al malware di conoscere la configurazione linguistica della macchina.

Oltre alla voce Run, tria.ge segnala la creazione o modifica di file nelle cartelle Startup dell'utente e di Microsoft Word. Anche queste posizioni possono essere sfruttate per avviare automaticamente un file quando l'utente accede al sistema o apre l'applicazione.

3.3 File e componenti rilasciati

tasksche.exe è il componente collegato alla voce Run e quindi quello più chiaramente associato alla persistenza. taskdl.exe viene eseguito più volte durante l'analisi, mentre taskhsvc.exe opera nella cartella TaskData\Tor e carica le librerie del pacchetto Tor. Il report mostra inoltre tor.exe, ssleay32.dll, libeay32.dll, zlib1.dll e altre DLL necessarie alla comunicazione cifrata.

Sono presenti anche un file batch, lo script m.vbs, la nota @Please_Read_Me@.txt e numerosi file .wnry contenenti risorse e messaggi in varie lingue. Il report non consente di assegnare con certezza una funzione precisa a ogni singolo file, ma l'insieme degli elementi conferma la preparazione della richiesta di riscatto, della persistenza e del canale di comunicazione Tor.

4. Analisi del traffico di rete

La cattura PCAPNG contiene 1.819 pacchetti registrati in circa 303 secondi: 1.762 pacchetti TCP, 12 UDP, 4 ICMP e 41 ARP. L'host analizzato utilizza l'indirizzo 10.127.0.71. Una parte del traffico appartiene al normale funzionamento della macchina sandbox, mentre le connessioni più interessanti sono collegate ai componenti Tor rilasciati dal malware.

4.1 Connessioni rilevanti e possibili C2

Un server C2, o Command and Control, è un sistema usato dal malware per ricevere istruzioni o scambiare dati. In questo caso il report mostra l'uso di Tor: di conseguenza non emerge un singolo dominio C2 fisso e confermato. Gli indirizzi seguenti devono quindi essere considerati endpoint di rete osservati durante l'analisi, non server C2 permanenti.

Destinazione	Porta	Osservazione
193.23.244.244	TCP/443	È la sessione cifrata principale della cattura: circa 1.429 pacchetti e oltre 1 MB di dati applicativi. Il ClientHello usa il nome SNI www.eiknmzjgup3q.com ; il certificato presenta il nome www.b6vr4ngnv.net , emesso da www.s733pnxx4dqo2.com . I nomi casuali e i componenti Tor estratti rendono la connessione sospetta, ma non provano un C2 stabile.
128.31.0.39	TCP/9101	Tentativo di connessione molto breve, senza trasferimento applicativo significativo. La porta e il contesto sono compatibili con la ricerca di un nodo o servizio Tor.
212.47.229.2	TCP/9001	Endpoint riportato nella prima esecuzione comportamentale di tria.ge . La porta 9001 è coerente con comunicazioni Tor; l'indirizzo non compare nella cattura PCAPNG della seconda esecuzione.
171.25.193.9	TCP/80	Altro indirizzo remoto osservato nel report di tria.ge . Deve essere trattato come indicatore contestuale della singola esecuzione e non come C2 confermato.

Il collegamento a 127.0.0.1:9050 è locale e corrisponde alla porta SOCKS normalmente utilizzata dal client Tor: non è quindi un C2 esterno. Le richieste DNS verso login.live.com, ctldl.windowsupdate.com, ocsp.digicert.com, settings-win.data.microsoft.com e nexusrules.officeapps.live.com appartengono invece a servizi Microsoft, Windows Update e DigiCert della macchina sandbox e non sono state considerate indicatori del malware.

5. Conclusioni

L'analisi di tria.ge ha identificato WannaCrypt0r.exe come campione WannaCry con punteggio 10/10. Il comportamento più grave è la combinazione tra cifratura dei file ed eliminazione dei sistemi di recupero. La voce Run che richiama tasksche.exe e i file inseriti nelle cartelle di avvio mostrano inoltre il tentativo di mantenere il malware attivo dopo il riavvio o un nuovo accesso dell'utente.

Il traffico di rete conferma l'avvio di componenti Tor e la comunicazione con diversi endpoint remoti. Poiché Tor nasconde la destinazione finale, gli IP e i nomi casuali osservati sono utili come indicatori della singola analisi, ma non devono essere descritti come C2 fissi senza ulteriori conferme. Il campione non è stato eseguito sulla FLARE-VM: tutte le attività dinamiche sono state svolte dalla sandbox online, come richiesto dalla traccia.